

PCI DSS v4.0 to v4.0.1 Transition Guide

Analysis of Key Clarifications, Corrections,
and Operational Impacts

Presented by

Fetri Miftach, PhD CEng MBCS CITP

PCI SSC June 2024 Update (Effective Industry Standard for 2026)

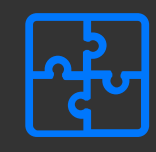


Executive Summary



The Big Picture:

Version 4.0.1 is a limited-scope revision (Correction/Maintenance update).



Zero New Requirements:

No new technical mandates or deletions of core criteria were introduced.



Primary Objective:

Eliminate ambiguities, fix typographical errors, and align text with SAQs (Self-Assessment Questionnaires).



Urgency:

Version 4.0 was formally retired on December 31, 2024. Version 4.0.1 is now the only active standard.

High-Level Change Summary Matrix

01

Requirement 3 (Data Protection):

Aligned encryption and Sensitive Authentication Data (SAD) exceptions for Issuers.

02

Requirement 6 (Software Security):

Clarified risk-ranking definitions for system vulnerability patching.

03

Requirement 8 (Access Control):

Refined Multi-Factor Authentication (MFA) scope and phishing-resistant criteria.

04

Appendices & Reporting:

Removed sample report templates from the text; moved exclusively to online portals.



Deep Dive – Requirement 3: Issuer SAD Storage

01. The Change:

Clarified Section 3.3.2 regarding Sensitive Authentication Data (SAD) storage prior to authorization.

02. Context in v4.0:

Text left ambiguity on whether issuers could retain certain data elements post-authorization under any condition.

03. The v4.0.1 Correction:

Explicitly confirms that issuers (and companies supporting issuer services) have a legal exception to store SAD if there is a justified, documented business need, provided it is secured.

04. Operational Impact:

Prevents compliance failures for banks and payment processors handling complex clearing/settlement workflows.

Deep Dive – Requirement 6: Vulnerability Patching Scope

01. The Change:

Refined Requirement 6.3.3 regarding the 30-day patching timeline.

02. Context in v4.0:

Phrasing implied all security vulnerabilities identified by risk assessments required a 30-day patch window.

03. The v4.0.1 Correction:

Clarifies that the strict 30-day remediation mandate applies strictly to "Critical" vulnerabilities as defined by the entity's risk ranking system.

04. Operational Impact:

Reduces operational strain on IT security teams by allowing risk-based prioritization for "High" and "Medium" non-critical bugs.

Deep Dive – Requirement 8: MFA Alignment

01. The Change:

Standardized language regarding Multi-Factor Authentication in Requirement 8.4.2 and 8.5.1.

02. Context in v4.0:

Mismatches existed between the main standard text and the wording found in specific SAQ verification procedures.

03. The v4.0.1 Correction:

Aligns terminology to explicitly state when MFA is required for all access to the Cardholder Data Environment (CDE), and clarifies definitions surrounding "phishing-resistant" authentication factors.

04. Operational Impact:

Ensures that third-party assessors (QSAs) and internal auditors use the exact same evaluation metrics, eliminating assessment friction.

Deep Dive – Administrative & Template Relocation

01. The Change:

Removal of extensive report templates from the main document body.

02. Context in v4.0:

Sample reporting forms and ROC (Report on Compliance) templates bloated the technical standard.

03. The v4.0.1 Correction:

Replaced static template appendices with direct digital alignment to the official, dynamic PCI SSC Document Library.

04. Operational Impact:

Assures compliance teams that they are always utilizing the latest version of forms without needing to wait for a standard-wide text overhaul.

Deep Dive – Administrative & Template Relocation

01. The Change:

Removal of extensive report templates from the main document body.

02. Context in v4.0:

Sample reporting forms and ROC (Report on Compliance) templates bloated the technical standard.

03. The v4.0.1 Correction:

Replaced static template appendices with direct digital alignment to the official, dynamic PCI SSC Document Library.

04. Operational Impact:

Assures compliance teams that they are always utilizing the latest version of forms without needing to wait for a standard-wide text overhaul.



Conclusion & Action Items

Document Update:

Immediately audit all internal security policies to cite PCI DSS v4.0.1 rather than v4.0.

Assessor Alignment:

Confirm with your QSA that your active Assessment Plan is calibrated precisely to v4.0.1.

Continuous Compliance:

Leverage the Customized Approach validation guidance updated in v4.0.1 for unique infrastructure setups.





VERSION CONTROL: v4.0 to v4.0.1

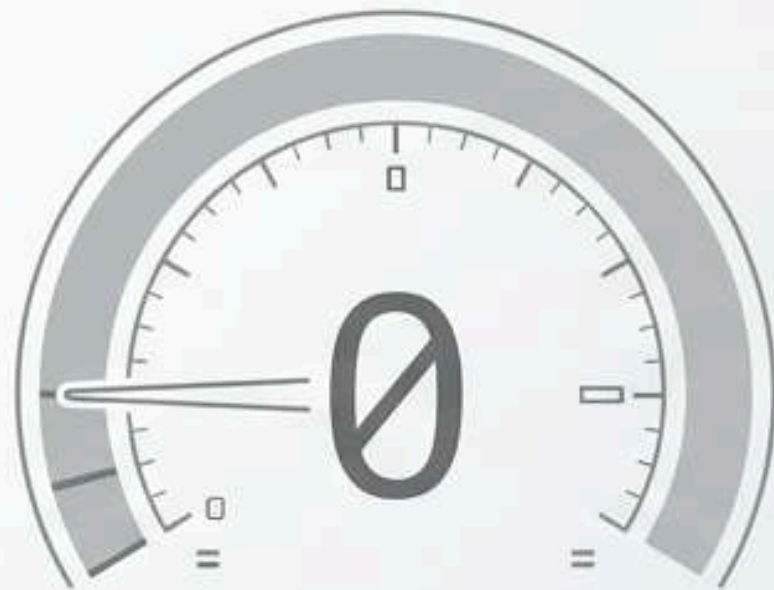
PCI DSS v4.0.1: The Refined Blueprint

A Strategic Navigator for Structural
Clarifications and Compliance Alignment



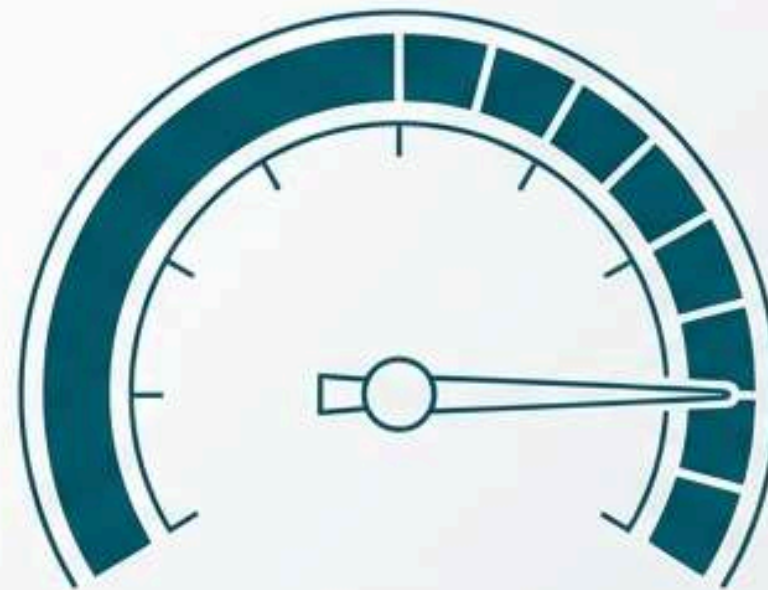
The Zero-Impact Baseline : No New Mandates

Evolving Requirement



0 Changes. No emerging threats or new technological mandates in this update.

Clarification or Guidance



Updates to wording, definitions, and instruction to eliminate auditor subjectivity.

Structure or Format



Reorganization, combining, and renumbering to align content.

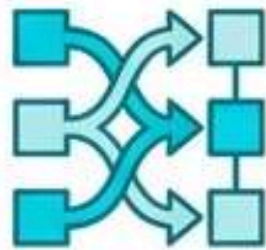
v4.0 built the infrastructure . v4.0.1 polishes the schematics

Master Legend: How to Read the Blueprint



[CLARIFICATION]

Replaces ambiguity. Updates wording, guidance, or instruction based on recently published FAQs and the v4.0 Quick Reference Guide.



[STRUCTURE]

Reorganizes content. Combines, separates, or renumbers requirements without changing the underlying mandate.

Global Terminology Shift

Before

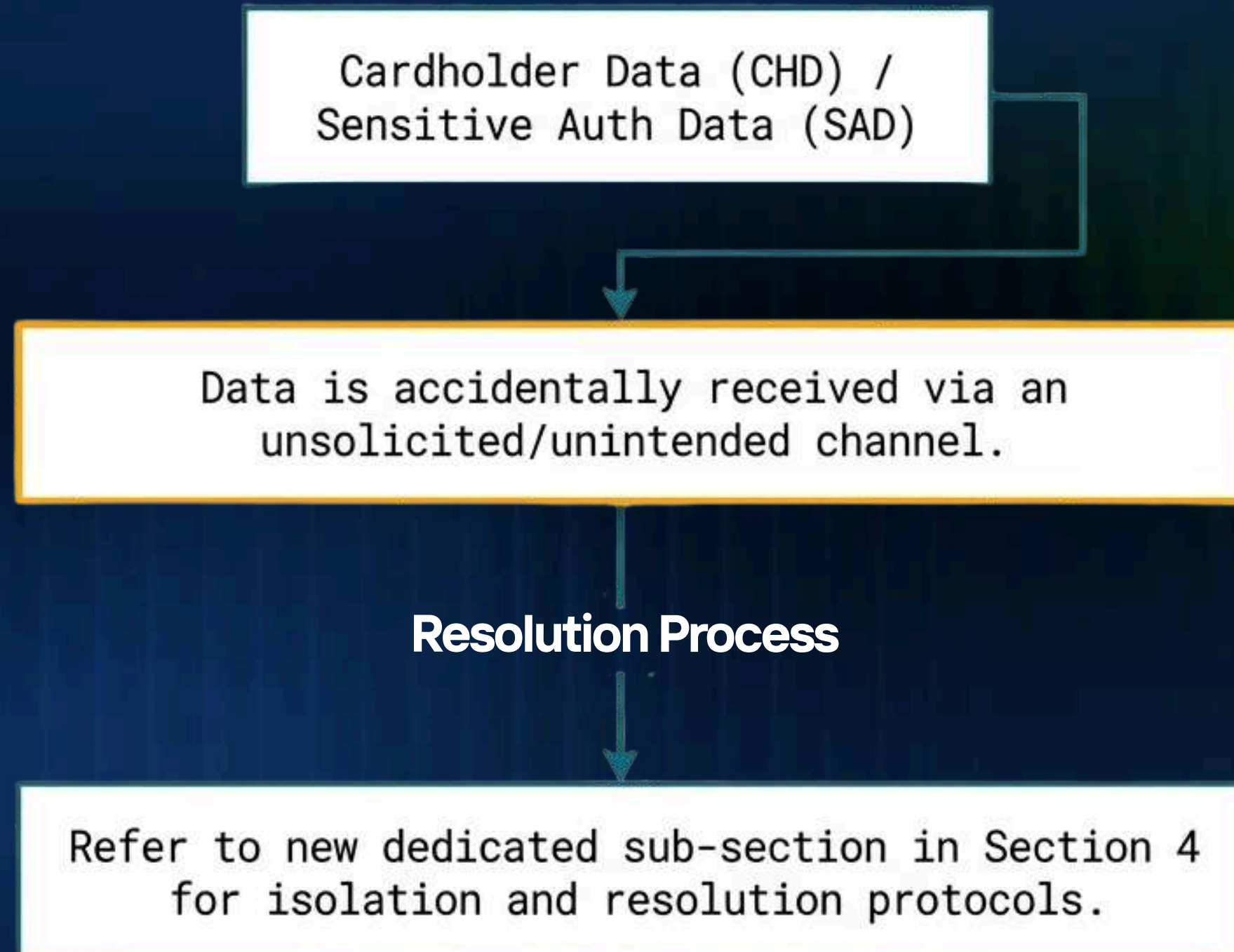
...impact the security of the CDE...

After

...impact the security of cardholder data and/or sensitive authentication data...

Applied universally throughout the standard to close scoping loopholes.

Scope Resolution: The Unintended Channel



TPSP Clarification

TPSPs must provide documentation about responsibilities only if they provide a service that meets PCI DSS requirements or impacts CHD/SAD security.

Validation, Timelines, & Administrative Updates



Sec 7: Timeframes

Clarifies 'Significant Change' definition.
Specifies that 'initial PCI DSS assessment' applies only when assessed for the first time against a requirement with a defined timeframe.



Sec 8 & App D: Customized Approach

Updates references to point directly to the new Sample Templates to Support the Customized Approach on the PCI SSC website.



Sec 3: Software Standards

Notes the official retirement of PA-DSS terminology.
Changes 'Validated Software Vendors' to 'Qualified Software Vendors.'



Sec 14: Version Control

Officially removes references to PCI DSS v3.2.1 (now retired).
Confirms v4.0.1 is the active standard alongside v4.0 until its retirement.

Data Protection Refinements: Rendering PAN & SAD

[CLARIFICATION]

Requirement 3 (PAN & SAD)

3.5.1, 3.5.1.1: Terminology

Changed Purpose from "The removal of cleartext PAN" to "Rendering PAN unreadable".

3.5.1: Hashing

Reconstructed PAN data with access to both truncated and hashed versions moved to Good Practice. Added that keyed cryptographic hashes are a valid control to prevent correlation.

3.3.1 & 3.3.3: SAD Storage

Clarified that SAD storage must be based on a "legitimate and documented issuing business need."

Requirement 9 (Physical Security)

9.2.1: Exemption

Added note that requirement does not apply to publicly accessible consumer locations.

9.3.4: Logs

Clarified wording to "visitor logs" (plural) and tracking "visitor activity both within pluri, and "visitor activity both within the facility and within sensitive areas."

Vulnerability Management: Reverting to Practicality

[CLARIFICATION]

Requirement 6.3.3 Patch Definitions

The v4.0 Stumble

~~Applied to high security patches/updates.~~

The v4.0.1 Fix (v3.2.1 Alignment)

Requirement applies to patches/updates
for critical vulnerabilities.

 **Removed**

The mandated “within three months of release” example is removed from the mandate and moved to Examples.

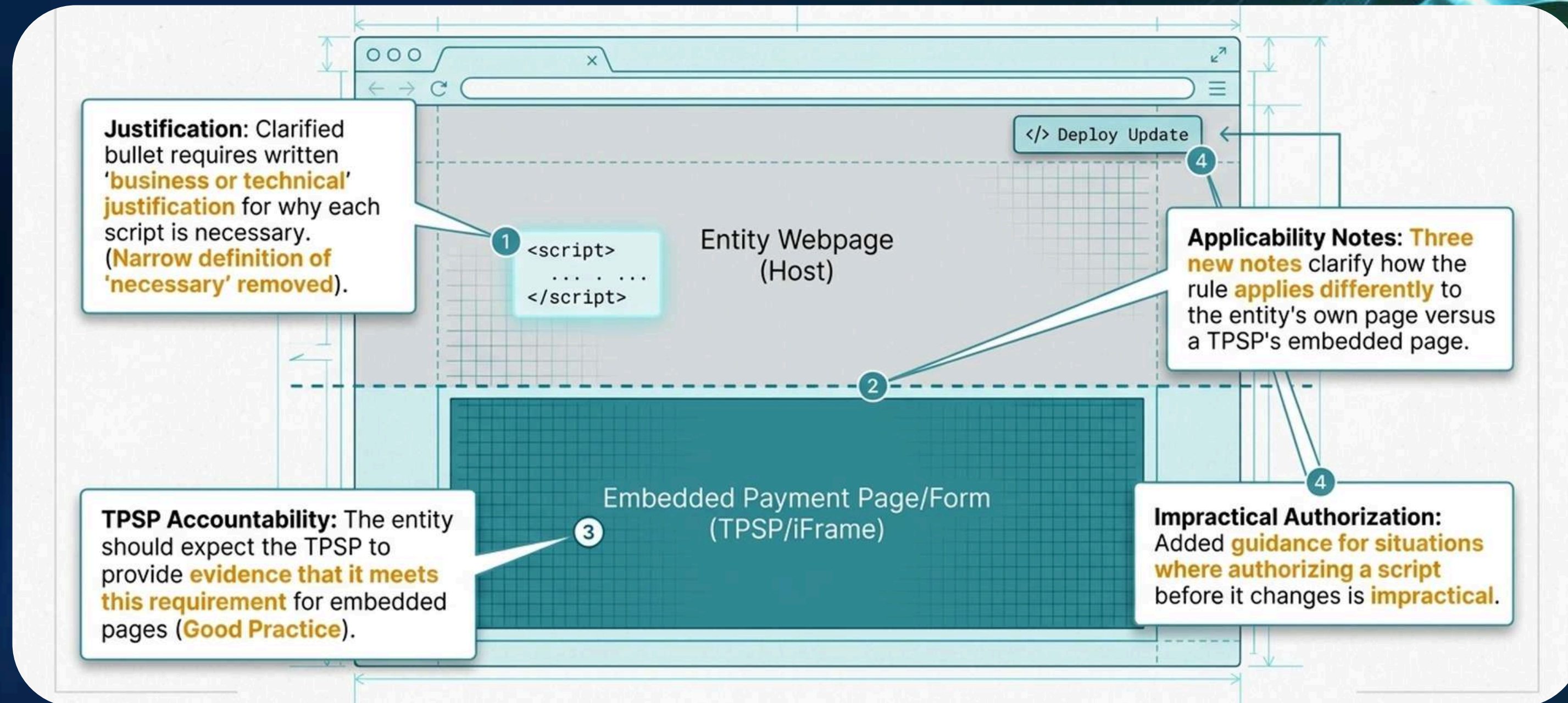
 **Targeted Risk**

Added to Good Practice that entities should complete a targeted risk analysis to determine frequency for all other applicable patches.

 **Vuln Scanning 11.3.1** Clarified that scans apply to vulnerabilities that are “either critical or high-risk.”

The E-Commerce Script Anatomy (Req 6.4.3)

[CLARIFICATION]



Identity & Access: Standardizing Terminology

[CLARIFICATION]

[STRUCTURE]

The “ID” Shift (Req 8.2.2)

~~ACCOUNTS~~ → **IDs**

Requirement updated to align with the Customized Approach Objective: targeting "group, shared, or generic IDs" rather than "accounts."

POS Exception (Req 8 General)

Clarified that certain requirements don't apply to user accounts on point-of-sale terminals accessing one card number at a time.

MFA & Remote Access (Req 8.3 & 8.4)

Scope (8.3.9)

Clarified that the requirement does not apply to in-scope system components where MFA is already used.

Phishing Exception (8.4.2)

Added note that the non-console access requirement does not apply to accounts using phishing-resistant authentication factors.

Nomenclature (8.4.3)

Clarified terminology from "remote network access" to simply "remote access" and added "third parties" to testing procedures.

Third-Party Risk & Strategic Alignment (Req 12)

[CLARIFICATION]



TPSP Acknowledgements (12.8.2, 12.9.1)

Precision in Language:

Changed vague pronouns ("they") to explicitly state "**TPSPs**" must address their own responsibilities.

Definitions:

Clarified the legal difference between an "**agreement**" and an "**acknowledgement**."
Acknowledgement confirms the TPSP is responsible.



Targeted Risk Analysis (12.3.1)

Scope Bound:

Clarified this applies only to PCI DSS requirements that **explicitly specify the completion** of a targeted risk analysis.

New Reference:

Added Further Information pointing to the PCI SSC's new **Targeted Risk Analysis guidance document and sample templates**.

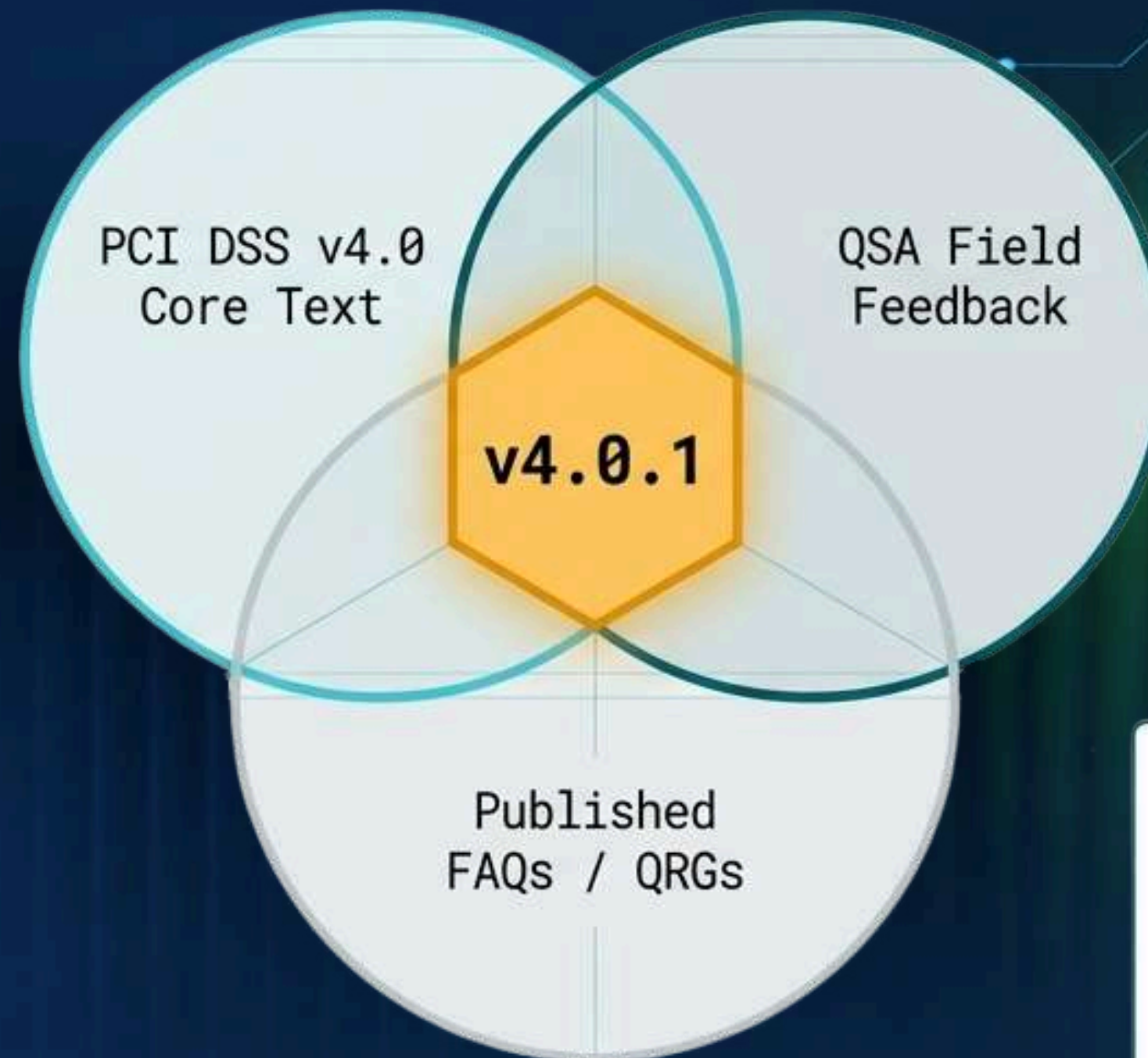
The v4.0 vs v4.0.1 Delta Matrix

Requirement Area	v4.0 Ambiguity	v4.0.1 Clarity Baseline
Patch Management (6.3.3)	'High-security patches'	Reverted to 'critical vulnerabilities' (v3.2.1 alignment).
Script Inventory (6.4.3)	Scripts 'necessary' for payment functionality only	Broadened to allow written 'business or technical' justification.
Account Terminology (8.2.2)	Broad interpretation of 'accounts'	Narrowed and aligned to 'group, shared, or generic IDs.'
TPSP Accountability (12.8.2)	Fuzzy line on who documents responsibility	Explicit requirement for TPSP written acknowledgement of responsibility

Synthesis: An Update of Alignment, Not Alteration

100% Subjectivity Reduction:

Every change serves to eliminate gray areas between assessors and entities (e.g., reverting patch language, defining "IDs").



Document Synchronization:

Guidance previously scattered across FAQs and the QRG is now natively codified in the primary standard.

Strategic Stagnation:

With exactly zero "Evolving Requirements," security roadmaps built for v4.0 remain completely valid and intact.

Operational Next Steps for Compliance Teams

01

Update Policy Terminology

Search and replace internal control language. Swap “accounts” for “IDs” in access policies, and update “CDE impact” language to “CHD/SAD impact” in scoping documents.

02

Adjust Patch Cadence

Resync automated patch management SLAs. Requirement 6.3.3 now strictly mandates timelines for “critical vulnerabilities” based on your risk ranking, removing the “high-security” ambiguity.

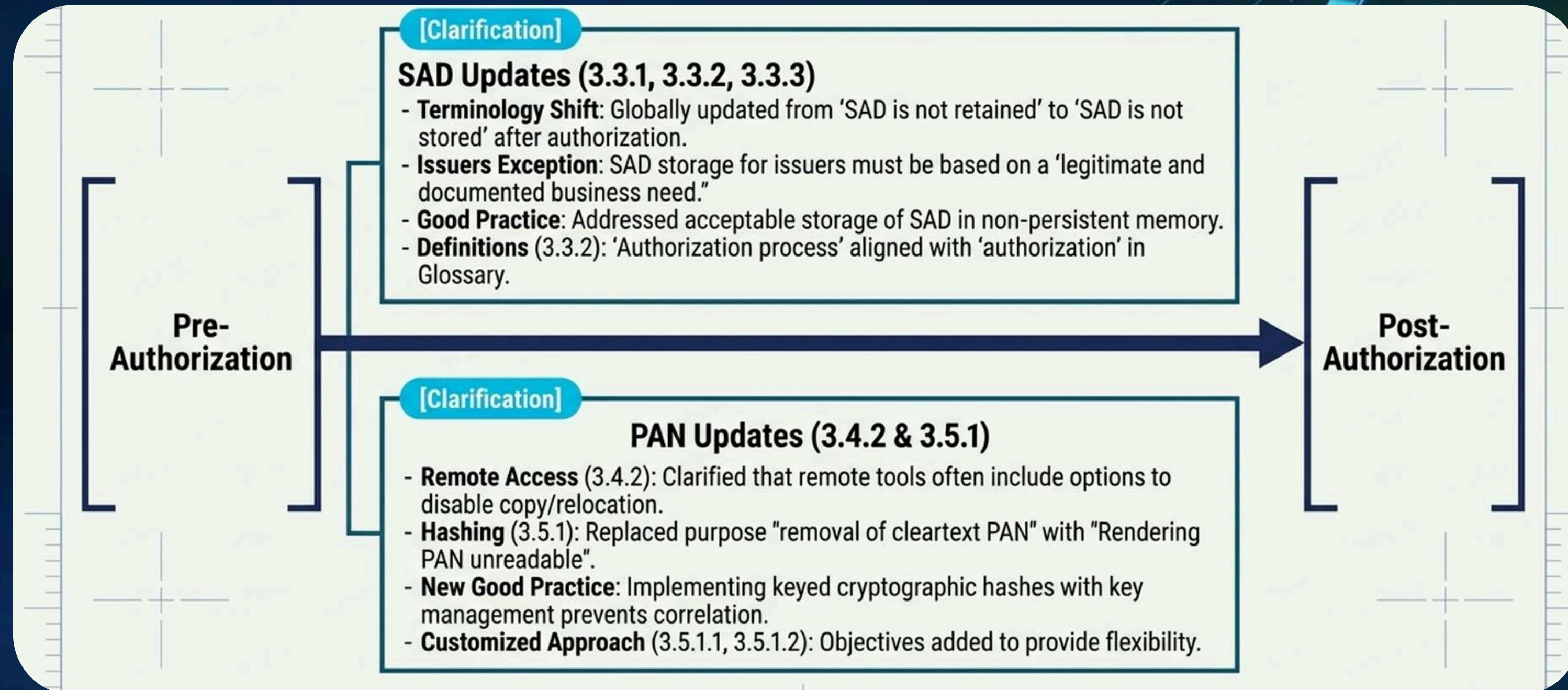
03

Review TPSP Checklists

Ensure third-party procurement and compliance checklists differentiate between legal “agreements” and explicit “acknowledgements” of PCI DSS responsibility for embedded pages and services.

PCI DSS v4.0.1 is effective immediately. v4.0 remains active until its retirement.

Requirement 3: Account Data Protection (Flow Schematic)



[Clarification]	
PCI DSS v4.0 Language	PCI DSS v4.0.1 Reversion
...installed for high security patches/updates within three months of release.	...installed for critical vulnerabilities.

Code Diff for Requirement 6

Req 6.3.3: Removed “within three months” from core text (moved to Examples). All other patches installed based on entity’s targeted risk analysis.

[Clarification]

Req 6.3.1 (Risk Ranking)

Clarified this is in addition to vuln scans in 11.3.1/11.3.2. Risk rankings should identify “high risk” or “critical” vulnerabilities.

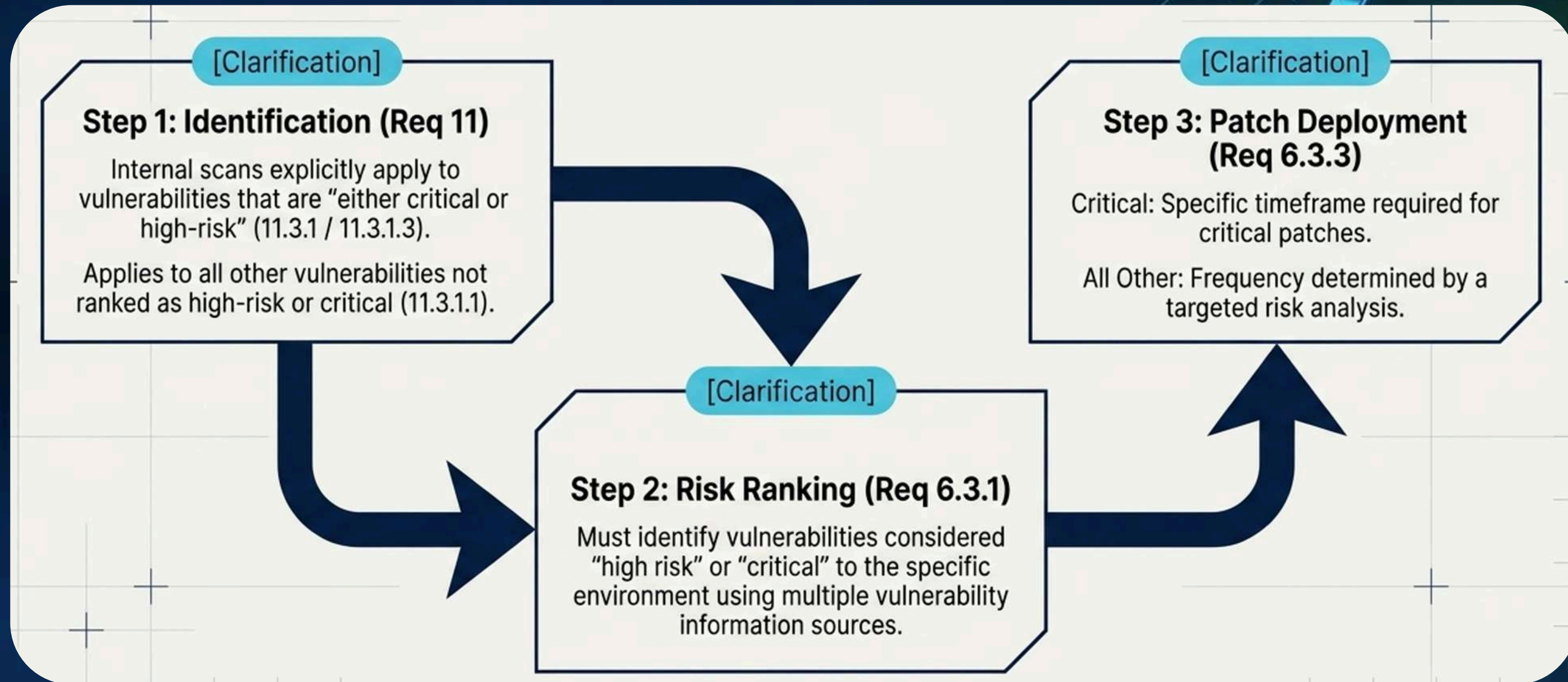
[Clarification]

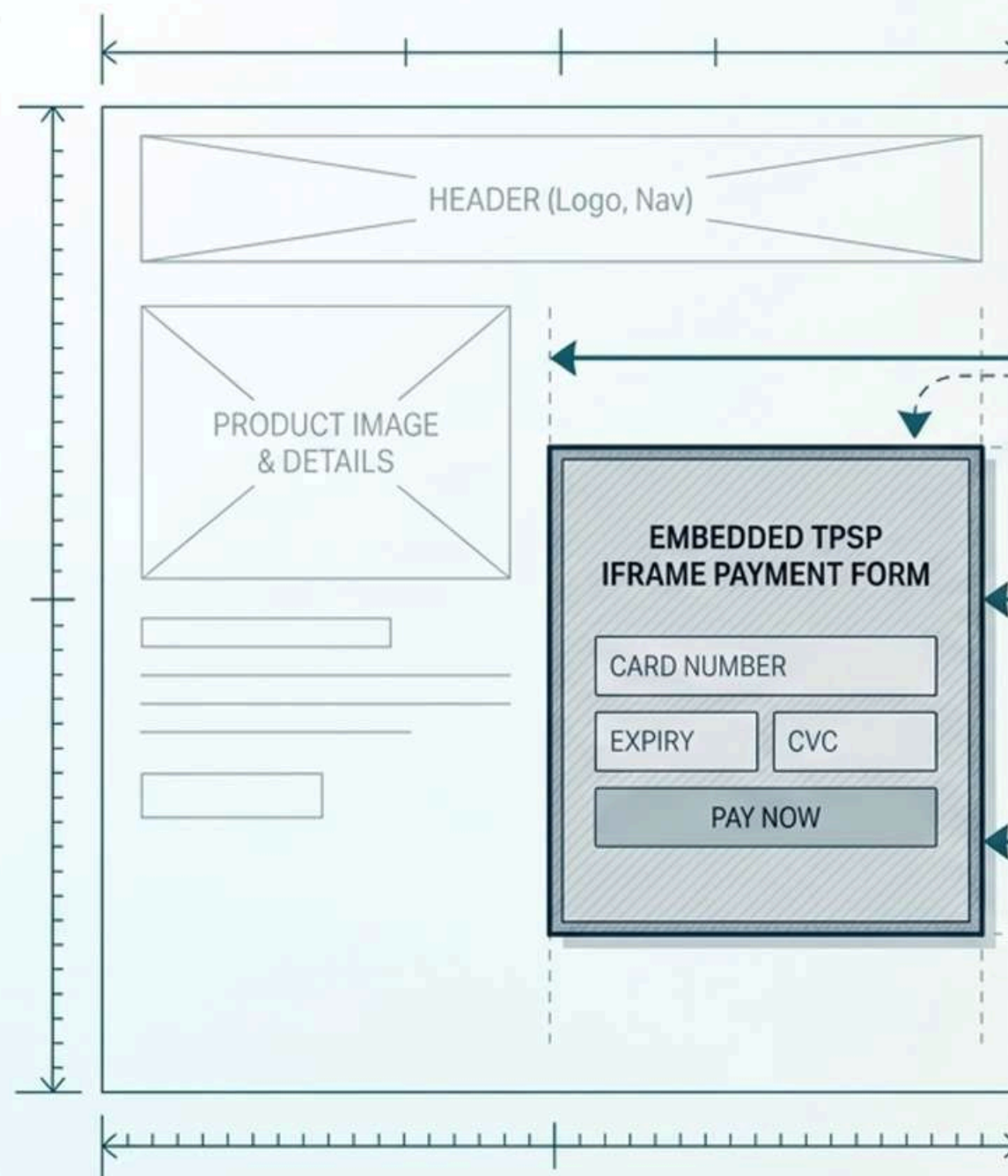
Req 6.5.5 (Live PANs)

Removed Good Practice on minimizing storage in pre-production. Clarified live PANs are those issued by/on behalf of a payment brand.

“Synthesis: The v4.0.1 Vulnerability Lifecycle”

mapping the intersection of Requirements 6 and 11





Req 6.4.3: Payment Page Scripts [Clarification]

The Inventory Rule: An inventory of scripts is maintained with written business or technical justification as to why each is necessary.

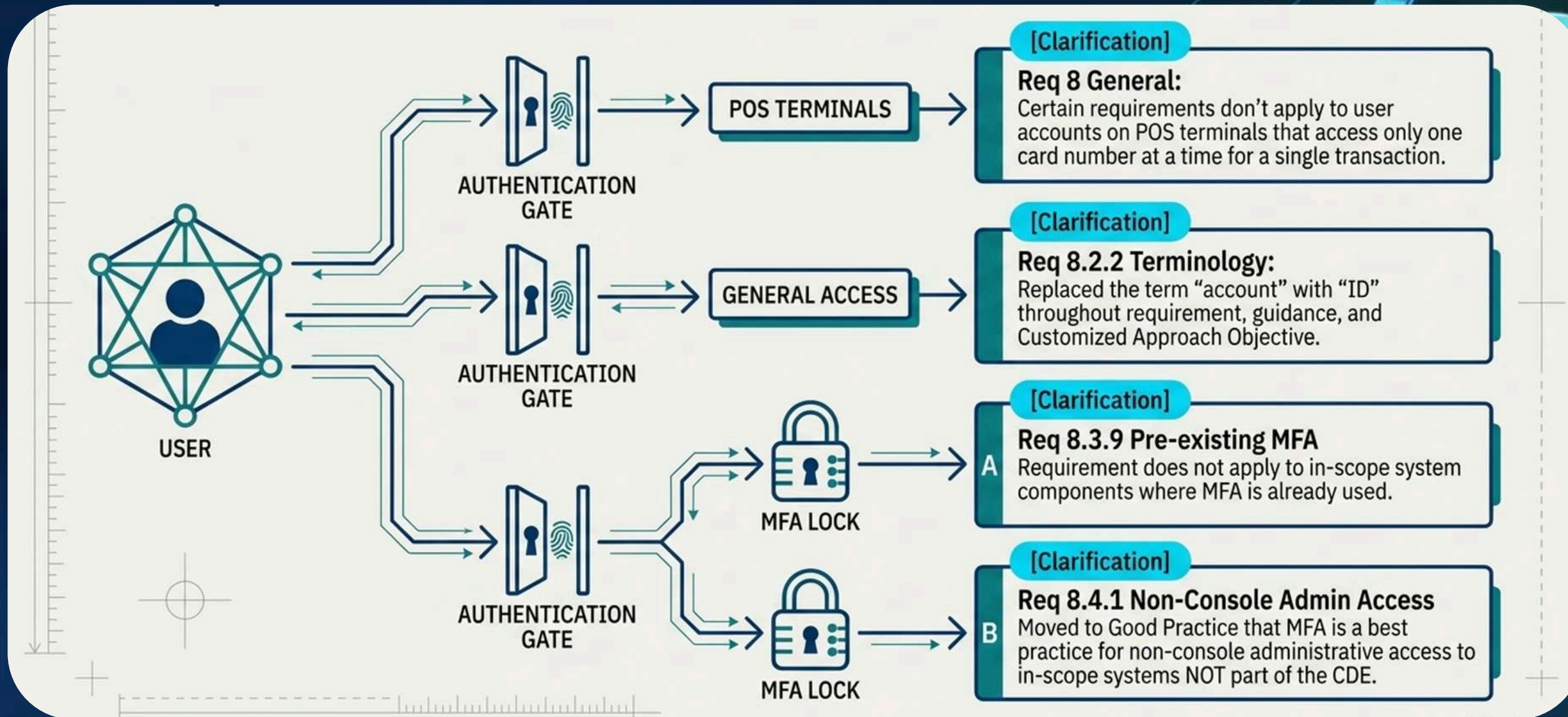
TPSP Scope: Requirement applies to BOTH the merchant's webpage AND a TPSP's embedded payment page/form.

Shared Responsibility: When embedding a TPSP's form, the entity should expect the TPSP to provide evidence they meet this script requirement.

Impracticality Clause: Added guidance for situations where it is impractical for scripts to be authorized before a script is changed or added.

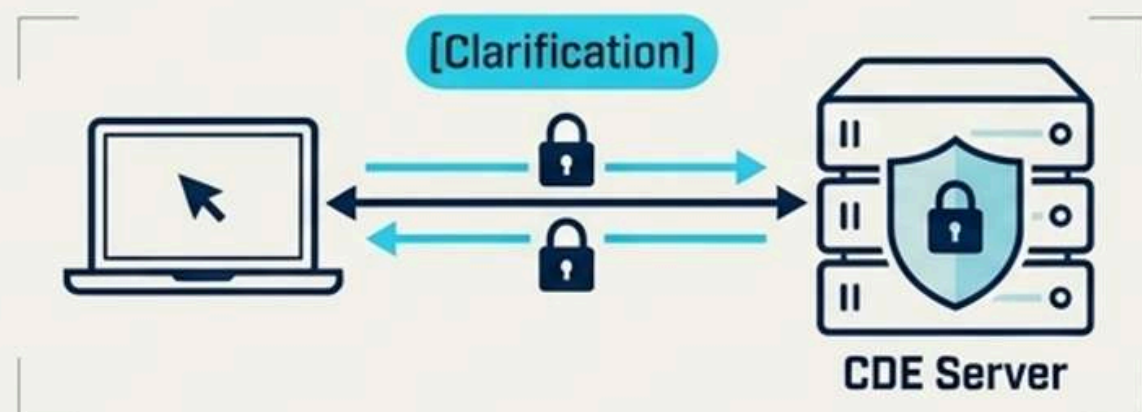


Req 8: User Access & Authentication Clarifications



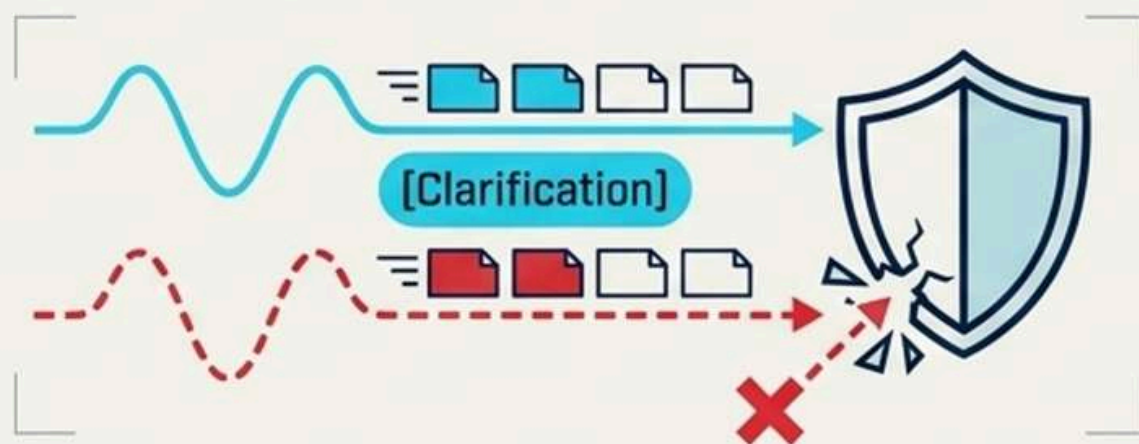
Remote Access Updates (8.4.2 & 8.4.3)

[CLARIFICATION]



- **Non-Console Access [8.4.2]:** Clarified requirement is for all “non-console” access into the CDE. Does not apply to user accounts authenticated only with phishing-resistant authentication factors.
- **Terminology [8.4.3]:** Changed “remote network access” to simply “remote access”. Added “third parties” to the testing procedure.

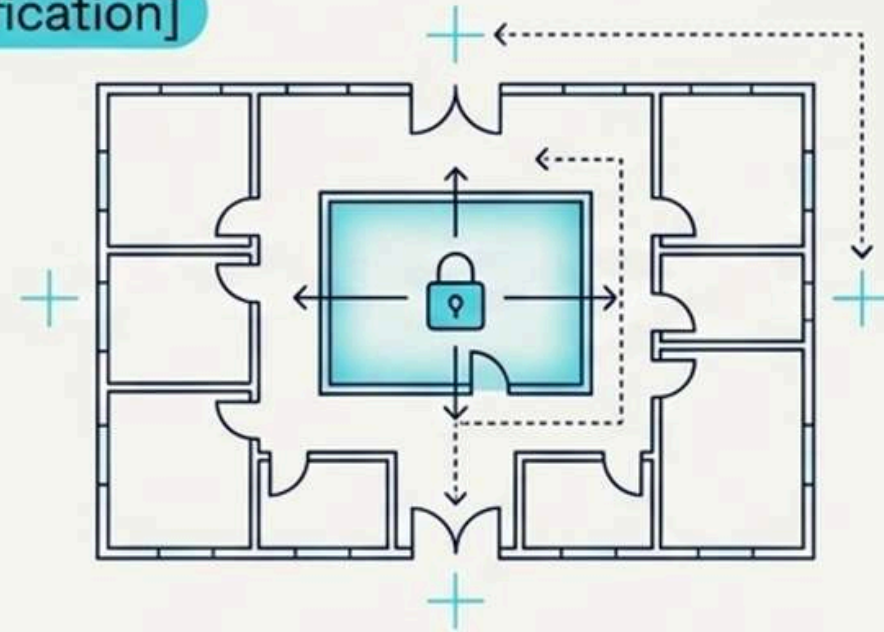
Replay Attacks [8.5.1] [Clarification]



- **Definition Added:** Added a specific definition for a “replay attack” under Definitions.
- **Examples Added:** Added examples of methods to help protect against replay attacks under the Examples section.

Requirement 9: Physical Security

[Clarification]



- **General:** Entities must identify 'sensitive areas' to ensure appropriate physical controls.
- **Public Access (9.2.1):** Does not apply to locations publicly accessible by consumers/cardholders.
- **Visitor Logs (9.3.4):** Tracks 'visitor activity both within the facility and within sensitive areas.'
- **Devices (9.5.1):** Consolidated Applicability Notes regarding which devices 9.5 does not apply to.

Requirement 10: Logging & Monitoring



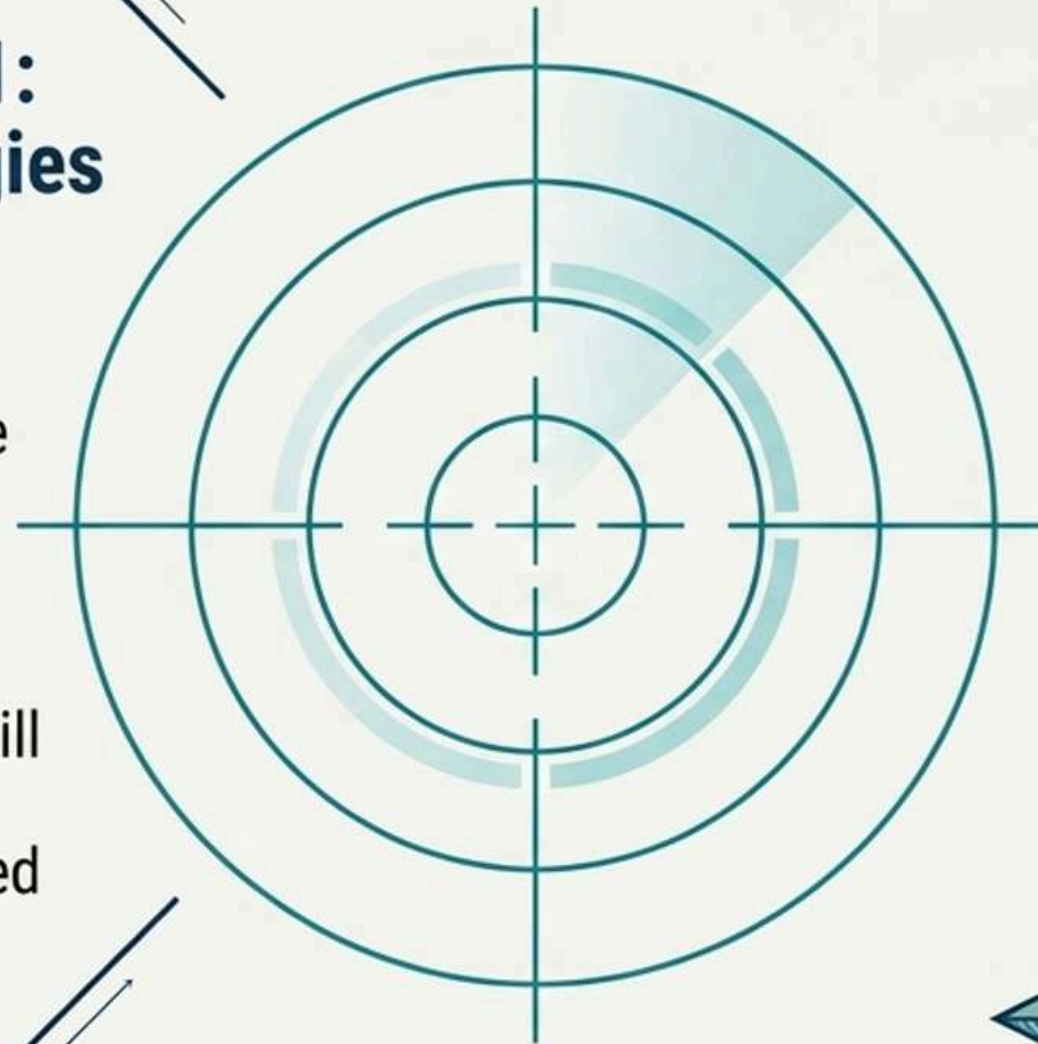
- **Audit Baselines (10.4.1.1):** Added info on establishing a baseline of normal audit activity under Good Practice. [Clarification]
- **Format Fix (10.5.1):** Updated 'Good Practice' heading to 'Purpose' to accurately reflect the section's content. [Format]

Requirement 11.2.1: Wireless Technologies

[Clarification]

Removed Applicability Note
and moved content to

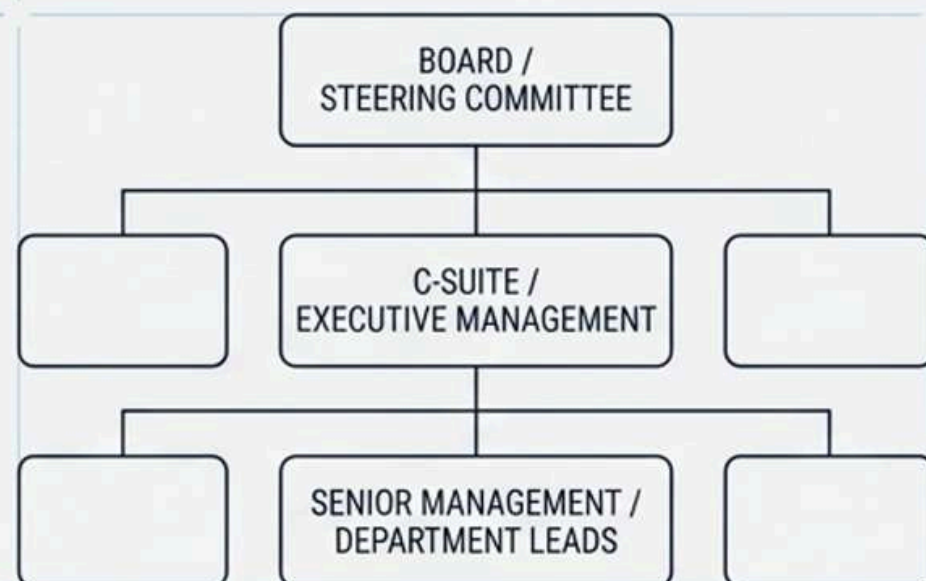
Purpose: Warns that
unauthorized use of
wireless technologies is still
possible even if the
company has a documented
policy prohibiting it.



Cross-Reference

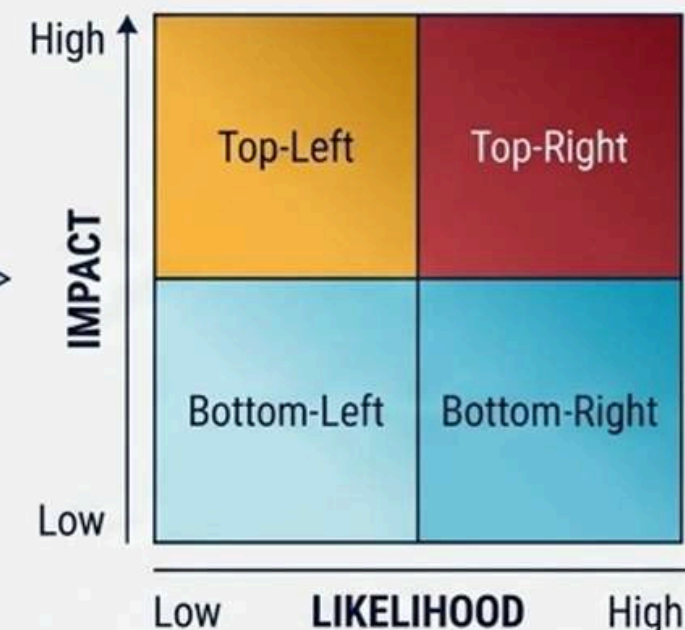
Note: The critical
clarifications regarding
High-Risk/Critical
Vulnerability Definitions
(11.3.1 series) are
synthesized in the
'Vulnerability Lifecycle'
flowchart on Slide 6.

Executive Oversight (12.1.4) [Clarification]



- **Titles:** Removed examples of common executive management titles from Purpose.
- **Seniority:** Moved description that these positions are at the "most senior level of management" to Good Good Practice.
- **Knowledge:** Added guidance on how information security knowledge for this role can be indicated.

Targeted Risk Analysis (12.3.1 & 12.3.3) [Clarification]



- **Scope Limitations** (12.3.1): Clarified requirement applies only to PCI DSS requirements that specifically mandate completion of a targeted risk analysis.
- **Justification:** Analysis must determine/justify how the defined frequency minimizes threat likelihood/impact. Added reference to PCI SSC TRA templates.
- **Crypto Plans** (12.3.3): Changed "A documented strategy" to "Documentation of a plan". Added examples of requirements needing cryptography.

Requirement 12: Third-Party Service Providers (TPSP)



Agreement

- **Pronoun Fix:** Clarified that acknowledgements address the TPSP's responsibility by changing the ambiguous "they" to "TPSPs".
- **Agreements vs. Agreements vs. Acknowledgements:** Applicability Notes to explicitly clarify the difference between an "agreement" and an "acknowledgement".
- **Confirmation:** The TPSP's written acknowledgment serves as confirmation that the TPSP is responsible.



Acknowledgement

- **Confirmation:** The TPSP's written acknowledgment serves as confirmation that the TPSP is responsible.
- **Evidence Examples:** Separated and expanded examples of evidence that show a TPSP meets PCI DSS requirements.
Applicability Scope (12.9.2): Removed "for any service the TPSP performs on behalf of customers" from the first bullet to clarify it applies to all TPSPs. The second bullet applies to TPSPs whose services meet customer requirements or impact account data security.

Synthesis: The TPSP Shared Responsibility Matrix (Synthesizing Section 12 & Introductory Section Changes)

The Documentation Delineation	
Agreements: Formal contracts defining the scope of services.	Acknowledgements (12.8.2/12.9.1): Written confirmation from the TPSP explicitly stating they are responsible for the security of the data they possess/impact.
Customer Obligations (12.8.2)	TPSP Obligations (12.9.1/12.9.2 & Intro)
- Must obtain written acknowledgements from TPSPs. - Must maintain evidence that the TPSP meets applicable PCI DSS requirements.	- Must provide written acknowledgements to customers. - Must provide documentation about responsibilities only if the TPSP provides a service that meets customers' PCI DSS or impacts the security of cardholder/SAD data.